

Safeguard 12.7: Ensure Remote Devices Utilize a VPN and are Connecting to an Enterprise's AAA Infrastructure

Asset Type: Devices	Security Function: Protect	IG2 IG3
----------------------------	-----------------------------------	-----------------------

Require users to authenticate to enterprise-managed VPN and authentication services prior to accessing enterprise resources on end-user devices.

Safeguard 12.8: Establish and Maintain Dedicated Computing Resources for All Administrative Work

Asset Type: Devices	Security Function: Protect	IG3
----------------------------	-----------------------------------	------------

Establish and maintain dedicated computing resources, either physically or logically separated, for all administrative tasks or tasks requiring administrative access. The computing resources should be segmented from the enterprise's primary network and not be allowed internet access.

CONTROL 13

Network Monitoring and Defense

Operate processes and tooling to establish and maintain comprehensive network monitoring and defense against security threats across the enterprise's network infrastructure and user base.

Safeguard 13.1: Centralize Security Event Alerting

Asset Type: Network	Security Function: Detect	IG2 IG3
----------------------------	----------------------------------	-----------------------

Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.

Safeguard 13.2: Deploy a Host-Based Intrusion Detection Solution

Asset Type: Devices	Security Function: Detect	IG2 IG3
----------------------------	----------------------------------	-----------------------

Deploy a host-based intrusion detection solution on enterprise assets, where appropriate and/or supported.

Safeguard 13.3: Deploy a Network Intrusion Detection Solution

Asset Type:	Network	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Deploy a network intrusion detection solution on enterprise assets, where appropriate. Example implementations include the use of a Network Intrusion Detection System (NIDS) or equivalent cloud service provider (CSP) service.

Safeguard 13.4: Perform Traffic Filtering Between Network Segments

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Perform traffic filtering between network segments, where appropriate.

Safeguard 13.5: Manage Access Control for Remote Assets

Asset Type:	Devices	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Manage access control for assets remotely connecting to enterprise resources. Determine amount of access to enterprise resources based on: up-to-date anti-malware software installed, configuration compliance with the enterprise’s secure configuration process, and ensuring the operating system and applications are up-to-date.

Safeguard 13.6: Collect Network Traffic Flow Logs

Asset Type:	Network	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Collect network traffic flow logs and/or network traffic to review and alert upon from network devices.

Safeguard 13.7: Deploy a Host-Based Intrusion Prevention Solution

Asset Type:	Devices	Security Function:	Protect	IG3
-------------	---------	--------------------	---------	-----

Deploy a host-based intrusion prevention solution on enterprise assets, where appropriate and/or supported. Example implementations include use of an Endpoint Detection and Response (EDR) client or host-based IPS agent.

Safeguard 13.8: Deploy a Network Intrusion Prevention Solution

Asset Type:	Network	Security Function:	Protect	IG3
-------------	---------	--------------------	---------	-----

Deploy a network intrusion prevention solution, where appropriate. Example implementations include the use of a Network Intrusion Prevention System (NIPS) or equivalent CSP service.

Safeguard 13.9: Deploy Port-Level Access Control

Asset Type:	Network	Security Function:	Protect	IG3
-------------	---------	--------------------	---------	-----

Deploy port-level access control. Port-level access control utilizes 802.1x, or similar network access control protocols, such as certificates, and may incorporate user and/or device authentication.

Safeguard 13.10: Perform Application Layer Filtering

Asset Type:	Network	Security Function:	Protect	IG3
-------------	---------	--------------------	---------	-----

Perform application layer filtering. Example implementations include a filtering proxy, application layer firewall, or gateway.

Safeguard 13.11: Tune Security Event Alerting Thresholds

Asset Type:	Network	Security Function:	Detect	IG3
-------------	---------	--------------------	--------	-----

Tune security event alerting thresholds monthly, or more frequently.

CONTROL 14

Security Awareness and Skills Training

Establish and maintain a security awareness program to influence behavior among the workforce to be security conscious and properly skilled to reduce cybersecurity risks to the enterprise.

Safeguard 14.1: Establish and Maintain a Security Awareness Program

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and maintain a security awareness program. The purpose of a security awareness program is to educate the enterprise’s workforce on how to interact with enterprise assets and data in a secure manner. Conduct training at hire and, at a minimum, annually. Review and update content annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 14.2: Train Workforce Members to Recognize Social Engineering Attacks

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members to recognize social engineering attacks, such as phishing, business email compromise (BEC), pretexting, and tailgating.

Safeguard 14.3: Train Workforce Members on Authentication Best Practices

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members on authentication best practices. Example topics include MFA, password composition, and credential management.

Safeguard 14.4: Train Workforce on Data Handling Best Practices

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members on how to identify and properly store, transfer, archive, and destroy sensitive data. This also includes training workforce members on clear screen and desk best practices, such as locking their screen when they step away from their enterprise asset, erasing physical and virtual whiteboards at the end of meetings, and storing data and assets securely.

Safeguard 14.5: Train Workforce Members on Causes of Unintentional Data Exposure

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members to be aware of causes for unintentional data exposure. Example topics include mis-delivery of sensitive data, losing a portable end-user device, or publishing data to unintended audiences.

Safeguard 14.6: Train Workforce Members on Recognizing and Reporting Security Incidents

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members to be able to recognize a potential incident and be able to report such an incident.

Safeguard 14.7: Train Workforce on How to Identify and Report if Their Enterprise Assets are Missing Security Updates

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce to understand how to verify and report out-of-date software patches or any failures in automated processes and tools. Part of this training should include notifying IT personnel of any failures in automated processes and tools.

Safeguard 14.8: Train Workforce on the Dangers of Connecting to and Transmitting Enterprise Data Over Insecure Networks

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Train workforce members on the dangers of connecting to, and transmitting data over, insecure networks for enterprise activities. If the enterprise has remote workers, training must include guidance to ensure that all users securely configure their home network infrastructure.

Safeguard 14.9: Conduct Role-Specific Security Awareness and Skills Training

Asset Type: Users	Security Function: Protect	IG2	IG3
-------------------	----------------------------	-----	-----

Conduct role-specific security awareness and skills training. Example implementations include secure system administration courses for IT professionals, OWASP® Top 10 vulnerability awareness and prevention training for web application developers, and advanced social engineering awareness training for high-profile roles.

CONTROL 15

Service Provider Management

Develop a process to evaluate service providers who hold sensitive data, or are responsible for an enterprise’s critical IT platforms or processes, to ensure these providers are protecting those platforms and data appropriately.

Safeguard 15.1: Establish and Maintain an Inventory of Service Providers

Asset Type: Users	Security Function: Identify	IG1	IG2	IG3
-------------------	-----------------------------	-----	-----	-----

Establish and maintain an inventory of service providers. The inventory is to list all known service providers, include classification(s), and designate an enterprise contact for each service provider. Review and update the inventory annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 15.2: Establish and Maintain a Service Provider Management Policy

Asset Type: Documentation	Security Function: Govern	IG2	IG3
---------------------------	---------------------------	-----	-----

Establish and maintain a service provider management policy. Ensure the policy addresses the classification, inventory, assessment, monitoring, and decommissioning of service providers. Review and update the policy annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 15.3: Classify Service Providers

Asset Type: Users	Security Function: Govern	IG2	IG3
-------------------	---------------------------	-----	-----

Classify service providers. Classification consideration may include one or more characteristics, such as data sensitivity, data volume, availability requirements, applicable regulations, inherent risk, and mitigated risk. Update and review classifications annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 15.4: Ensure Service Provider Contracts Include Security Requirements

Asset Type: Documentation	Security Function: Govern	IG2	IG3
---------------------------	---------------------------	-----	-----

Ensure service provider contracts include security requirements. Example requirements may include minimum security program requirements, security incident and/or data breach notification and response, data encryption requirements, and data disposal commitments. These security requirements must be consistent with the enterprise's service provider management policy. Review service provider contracts annually to ensure contracts are not missing security requirements.

Safeguard 15.5: Assess Service Providers

Asset Type: Users	Security Function: Govern	IG3
-------------------	---------------------------	-----

Assess service providers consistent with the enterprise's service provider management policy. Assessment scope may vary based on classification(s), and may include review of standardized assessment reports, such as Service Organization Control 2 (SOC 2) and Payment Card Industry (PCI) Attestation of Compliance (AoC), customized questionnaires, or other appropriately rigorous processes. Reassess service providers annually, at a minimum, or with new and renewed contracts.

Safeguard 15.6: Monitor Service Providers

Asset Type: Data	Security Function: Govern	IG3
------------------	---------------------------	-----

Monitor service providers consistent with the enterprise's service provider management policy. Monitoring may include periodic reassessment of service provider compliance, monitoring service provider release notes, and dark web monitoring.

Safeguard 15.7: Securely Decommission Service Providers

Asset Type: Data	Security Function: Protect	IG3
------------------	----------------------------	-----

Securely decommission service providers. Example considerations include user and service account deactivation, termination of data flows, and secure disposal of enterprise data within service provider systems.

CONTROL 16

Application Software Security

Manage the security life cycle of in-house developed, hosted, or acquired software to prevent, detect, and remediate security weaknesses before they can impact the enterprise.

Safeguard 16.1: Establish and Maintain a Secure Application Development Process

Asset Type: Documentation	Security Function: Govern	IG2 IG3
---------------------------	---------------------------	---------

Establish and maintain a secure application development process. In the process, address such items as: secure application design standards, secure coding practices, developer training, vulnerability management, security of third-party code, and application security testing procedures. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 16.2: Establish and Maintain a Process to Accept and Address Software Vulnerabilities

Asset Type: Documentation	Security Function: Govern	IG2 IG3
---------------------------	---------------------------	---------

Establish and maintain a process to accept and address reports of software vulnerabilities, including providing a means for external entities to report. The process is to include such items as: a vulnerability handling policy that identifies reporting process, responsible party for handling vulnerability reports, and a process for intake, assignment, remediation, and remediation testing. As part of the process, use a vulnerability tracking system that includes severity ratings and metrics for measuring timing for identification, analysis, and remediation of vulnerabilities. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Third-party application developers need to consider this an externally-facing policy that helps to set expectations for outside stakeholders.

Safeguard 16.3: Perform Root Cause Analysis on Security Vulnerabilities

Asset Type: **Software**

Security Function: **Protect**

IG2

IG3

Perform root cause analysis on security vulnerabilities. When reviewing vulnerabilities, root cause analysis is the task of evaluating underlying issues that create vulnerabilities in code, and allows development teams to move beyond just fixing individual vulnerabilities as they arise.

Safeguard 16.4: Establish and Manage an Inventory of Third-Party Software Components

Asset Type: **Software**

Security Function: **Identify**

IG2

IG3

Establish and manage an updated inventory of third-party components used in development, often referred to as a “bill of materials,” as well as components slated for future use. This inventory is to include any risks that each third-party component could pose. Evaluate the list at least monthly to identify any changes or updates to these components, and validate that the component is still supported.

Safeguard 16.5: Use Up-to-Date and Trusted Third-Party Software Components

Asset Type: **Software**

Security Function: **Protect**

IG2

IG3

Use up-to-date and trusted third-party software components. When possible, choose established and proven frameworks and libraries that provide adequate security. Acquire these components from trusted sources or evaluate the software for vulnerabilities before use.

Safeguard 16.6: Establish and Maintain a Severity Rating System and Process for Application Vulnerabilities

Asset Type: **Documentation**

Security Function: **Govern**

IG2

IG3

Establish and maintain a severity rating system and process for application vulnerabilities that facilitates prioritizing the order in which discovered vulnerabilities are fixed. This process includes setting a minimum level of security acceptability for releasing code or applications. Severity ratings bring a systematic way of triaging vulnerabilities that improves risk management and helps ensure the most severe bugs are fixed first. Review and update the system and process annually.

Safeguard 16.7: Use Standard Hardening Configuration Templates for Application Infrastructure

Asset Type: Software	Security Function: Protect	IG2	IG3
-----------------------------	-----------------------------------	------------	------------

Use standard, industry-recommended hardening configuration templates for application infrastructure components. This includes underlying servers, databases, and web servers, and applies to cloud containers, Platform as a Service (PaaS) components, and SaaS components. Do not allow in-house developed software to weaken configuration hardening.

Safeguard 16.8: Separate Production and Non-Production Systems

Asset Type: Network	Security Function: Protect	IG2	IG3
----------------------------	-----------------------------------	------------	------------

Maintain separate environments for production and non-production systems.

Safeguard 16.9: Train Developers in Application Security Concepts and Secure Coding

Asset Type: Users	Security Function: Protect	IG2	IG3
--------------------------	-----------------------------------	------------	------------

Ensure that all software development personnel receive training in writing secure code for their specific development environment and responsibilities. Training can include general security principles and application security standard practices. Conduct training at least annually and design in a way to promote security within the development team, and build a culture of security among the developers.

Safeguard 16.10: Apply Secure Design Principles in Application Architectures

Asset Type: Software	Security Function: Protect	IG2	IG3
-----------------------------	-----------------------------------	------------	------------

Apply secure design principles in application architectures. Secure design principles include the concept of least privilege and enforcing mediation to validate every operation that the user makes, promoting the concept of “never trust user input.” Examples include ensuring that explicit error checking is performed and documented for all input, including for size, data type, and acceptable ranges or formats. Secure design also means minimizing the application infrastructure attack surface, such as turning off unprotected ports and services, removing unnecessary programs and files, and renaming or removing default accounts.